

A Security and Governance Framework for Generative AI in Healthcare

Gunn Arora Dept. of Computer Science & Engineering Chitkara University Punjab, India gunn333.be22@chitkara.edu.in	Khushi Sikka Dept. of Computer Science & Engineering Chitkara University Punjab, India khushi1018.be22@chitkara.edu.in	Sarthak Sadhotra Dept. of Computer Science & Engineering Chitkara University Punjab, India sarthak2264.be22@chitkara.edu.in
--	--	--

ABSTRACT

The rapid advancement of Generative AI technology in health care systems is creating a new age of medicine with the potential to provide unparalleled levels of assistance in making decisions related to patient care, diagnostics, research and development of drugs and automating administrative functions. However, the speed at which this technology is developing has far surpassed the regulatory clarity and architectural considerations necessary to safely deploy such technologies in clinical settings. As a result, the health care industry faces two major challenges; the first challenge being defining what boundaries of medical authority are applicable when using probabilistic forms of artificial intelligence, and secondly there are significant cyber-security risks associated with all data intensive models of generative AI. This document provides a unifying framework for governing the use of GenAI by combining elements from philosophical inquiry into the nature of medicine, systematic clinical application analysis and established methodologies from the field of cyber-security. A proposed Three-Phase Lifecycle Assessment Model (Data Collection Phase, Model Training Phase and Implementation Phase) is developed to map GenAI functionality against six key threat vectors including: data poisoning, adversarial manipulation, hallucinations, membership inference attacks, model inversion attacks and re-identification attacks. An evaluation protocol called Trustworthy AI Evaluation Protocol (TAEP) is also provided which consists of four quantifiable metrics: Inscrutability (I-score), Trustworthiness (T-score), Responsibility (R-score) and Harm Assessment (H-score). Additionally, a four tier Risk Strata Governance Model with specific pre-deployment Red Teaming Requirements and a Deterministic Runtime Semantic Validator (RSV) is proposed. A comparative review of current frameworks for regulating the use of AI in the United States (NIST Privacy Framework, US AI Bill of Rights), European Union (EU AI Act) and internationally (NIST AI RMF), indicates that while these frameworks establish regulatory requirements for the use of AI, they fail to address several important technical governance issues addressed in our lifecycle aware framework using techniques such as formal differential privacy guarantees, retrieval augmented generation and cryptographic audit infrastructure.

Keywords: Generative Artificial Intelligence, Healthcare Cybersecurity, AI Governance, Patient Privacy, Clinical Decision Support, Differential Privacy, Trustworthy AI, Retrieval-Augmented Generation.

I. INTRODUCTION

The emergence of Generative Artificial Intelligence (GenAI) as an operational technology within healthcare institutions signals a qualitative rupture from prior waves of medical informatics. Earlier generations of clinical software — rulebased expert systems, statistical decision-support tools, and

discriminative machine learning classifiers — operated by pattern-matching against predefined ontologies or learned correlations within bounded feature spaces. GenAI systems, by contrast, generate open-ended natural language, synthesise multimodal clinical evidence, and produce

probabilistic outputs across tasks previously exclusive to licensed clinicians: differential diagnosis formulation, treatment plan narration, surgical guidance commentary, and empathetic patient communication [1, 2]. The scale of deployment is no longer hypothetical. Large Language Models such as GPT-4, Med-PaLM 2, and GatorTron have demonstrated performance on medical licensing examinations at or above passing thresholds [3, 4, 5]. Multimodal foundation models trained on radiological corpora achieve diagnostic sensitivity in chest pathology detection comparable to board-certified radiologists under controlled evaluation conditions [6]. Natural language processing pipelines are actively deployed to reduce clinical documentation burden — clinicians report expenditure of 35– 50% of working hours on administrative tasks [7, 8]. The global healthcare AI market is projected to exceed USD 188 billion by 2030 [9]. Three structural problems define the present governance crisis. First, no established consensus exists on the boundary between clinical decision support and decision substitution; automation bias arises when GenAI generates confidently-framed medication recommendations [10, 11]. Second, data poisoning, membership inference attacks, and hallucination phenomena represent structural vulnerabilities with no precedent in prior healthcare IT [12–15]. Third, the regulatory landscape is fragmented and temporally misaligned with deployment velocity [16–19]. This paper addresses these three problems through a unified framework and makes four contributions: (1) a nine-domain GenAI healthcare taxonomy with risk profiles; (2) a ThreePhase Lifecycle Threat Model mapping six principal threat vectors; (3) a Risk-Stratified Governance Model with four TAEP metrics; and (4) lifecycle-aware risk assessment protocols with pre-deployment red-teaming requirements. These steps should be followed in rewriting the text. First I introduce the software prototype which is developed for keyword extraction, then I describe how a user can interact with it. reviews background and related literature. Section III presents the application taxonomy. Section IV develops the three-phase lifecycle architecture. Section V specifies security threat mechanisms. Section VI analyses the regulatory governance landscape. Section VII introduces the governance model and TAEP. Section VIII details mitigation strategies. Section IX discusses implications. Section X concludes.

II. BACKGROUND AND RELATED WORK

A. Generative AI in Healthcare

Early in the evolution of transformer-based architecture, it became apparent to researchers, there existed a theoretical capability for Neural Language Models in medicine [20]. Following this discovery, Singhal et al. [3], demonstrated Med-PaLM achieved U.S.M.L.E.-comparable results as a result of Medical Fine-Tuning, subsequent research using Med-PaLM 2 [4], resulted in Expert-Level Performance on multiple Clinical Benchmarks. Yang et al. [5], introduced Gator-Tron (pre-trained on 8.9B Parameters with 90B Words of De-Identified EHR Data), demonstrating that Domain-Specific Corpora can generate significant improvements over General-Purpose Pre-Training. Rajpurkar et al. [6], demonstrated Radiologist-Level Sensitivity for Pneumonia Detection from Chest Radiograph Archives. Tierney et al. [23], developed an Ambient AI Clinical Scribe which reduced Physician Documentation Time by 28 Minutes Per Day Across 422 Physicians — the First Rigorous Real-World Evidence of Operational GenAI Benefit. Fraile Navarro et al., [41] discovered Clinicians Prefer Medium Automation Levels Over High Automation due to concerns regarding Medico-Legal Responsibility and Risks associated with Automation Bias.

B. Security Vulnerabilities in Medical AI:

The likelihood ratio attack was formalized by Carlini et al. [26], that demonstrated differential privacy models can be breached with high true positive results. A malicious user could potentially disrupt AI clinical recommendations by introducing a very few number of specific data sets into an AI's training model according to Goldblum et al. [27]. Systematic racial biases were found in GPT-4 responses to clinical vignettes; these biases are due to the original training dataset, and therefore cannot be corrected using prompts alone according to Omiye et al. [32].

C. Governance Frameworks

The NIST AI Risk Management Framework (AI RMF 1.0) provides a way to handle AI risks. It focuses on four areas: Govern, Map, Measure and Manage. This framework is voluntary which makes it less effective in healthcare where strict rules are

needed. The EU AI Act starting in August 2024 classifies tools that help doctors make decisions as "risk." In the US the AI Bill of Rights gives five principles but they are not legally binding.

All these frameworks lack technical guidance that looks at AI systems throughout their lifespan. Our work aims to fill this gap by offering a way to model threats across an AIs journey. We tie together regulations and provide specific step-by-step plans for various risk levels. This approach is more detailed, than broad ideas. Our goal is to help manage AI risks in a practical way. We focus on AI risks. Provide a clear plan to handle them. AI systems have a journey and our approach considers that.

III. TAXONOMY OF GENAI APPLICATIONS

Healthcare applications for GenAI are diverse and fall across both clinical and administrative tasks that have different risk profiles based upon how directly AI Model Output affects patient outcome, the ability to correct an error once it has occurred and whether there is sufficient oversight from humans. The taxonomy is organized in this way as shown below (Table I).

Application	Output	Risk	Failure Mode	Key Control
Treatment Planning	Clin. text	HIGH	Hallucination, contraindication	RAG + RSV drug gate
Diagnostic Imaging	Image+ text	HIGH	Adversarial, OOD distribution	Adv. training + OOD
Surgical Assistance	RT overlay	CRITICAL	Latency, mis-calibration	Sub-100ms edge infr.
Clinical Docs	Struct. text	MODERATE	Automation bias, code error	HITL routing marker
Synthetic Data	Records	MODERATE	Membership inf., bias ampl.	DP-GAN ($\epsilon \leq 5.0$)
Drug Discovery	Mol. struct.	MODERATE	Dual-use, gen. toxicity	Output filter+classifier

Medical Education	Ped. text	MODERATE	Hallucination, bias prop.	SelfCheckGPT + eval
Revenue Cycle	Coded bill.	LOW	Coding error, fraud	Compliance audit
Patient Engagement	Conv.	MODERATE-HIGH	Unsafe triage, crisis	Escalation protocol

A. Clinical Applications

GenAI applications in healthcare span a broad spectrum of clinical and non-clinical functions, each presenting a distinct risk profile determined by the directness of model output on patient outcomes, error reversibility, and availability of human Table I. The structured taxonomy is presented. EHR parenting systems amalgamate patient view data, guidelines, and biomarker profiles, achieving 78–84% text [37]. The primary failure modes include relapse, toxicity, early death before reconstitution of immunity (after alignment with multidisciplinary tumour board recommendations in oncology [37]. The primary failure modes are hallucination of non-existent drug-gene interactions and systematic demographic bias in training-distribution mismatches [36]. Diagnostic imaging applications achieve radiologist-level sensitivity on narrow benchmarks (diabeticData poison. Re-identif. Gradient leak Adv. training Hallucination Prompt inject. retinopathy [38], pneumothorax, mammography) but exhibit dangerous out-of-distribution confidence degradation [39]. Surgical assistance operates under the strictest constraint sub-100ms intraoperative response precluding cloud-only architectures [40]. Clinical documentation scribes demonstrate 28-minute daily reduction but require mandatory clinician attestation [23, 41].

Synthetic patient data generation via VAE-GAN architectures addresses rare disease bottlenecks but requires DP training at $\epsilon \leq 5.0$ to prevent membership inference against small training cohorts [42, 43]. Drug discovery applications employing graph neural networks and AlphaFold-derived architectures present a dual-use threat specific to generative chemistry [44, 45].

B. Non-Clinical Applications

Medical Education Platforms create adaptive exam questions and clinical vignettes. A potential "Risk" of these systems would be Systemic

Epistemological Harm, where factual errors within the system become training data and subsequently affect patient treatment at large scales [46]. Revenue Cycle Management Systems automate the coding process using ICD-10-CM/CPT codes. The use of automated coding may expose organizations to fraudulent activities through liability [47].

IV. THREE-PHASE LIFECYCLE ARCHITECTURE

As opposed to treating security as a concern of the deployment phase, it is important to consider a lifecycle perspective on security. This perspective takes into account that different types of threats are more dangerous or more easily addressed during different stages in an application's development. Security can not be treated solely by using runtime controls for threats materialized during data collection or model training [15, 48] (See Fig. 1). The figure shows the complete three-phase structure of the system as well as specific threat mappings per phase

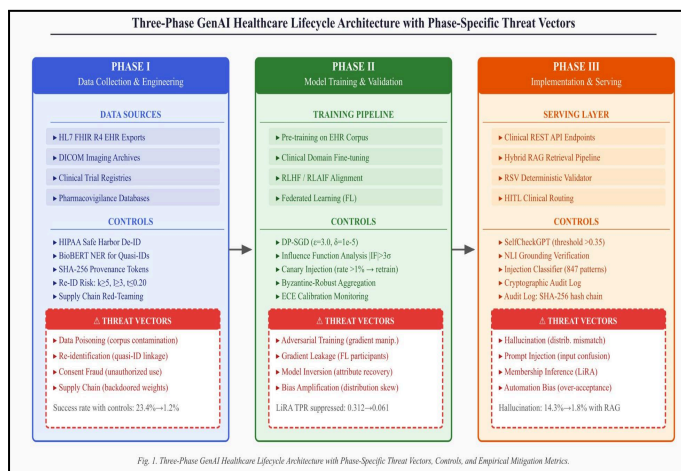


Fig. 1. Three-Phase GenAI Healthcare Lifecycle Architecture with Phase-Specific Threat Vectors, Controls, and Empirical Mitigation Metrics.

A. Phase I: Data Collection and Engineering

Healthcare training data originates from HL7 FHIR R4 EHR exports, DICOM archives, clinical trial registries (ClinicalTrials.gov, EU CTR), pharmacovigilance databases, and biomedical literature corpora. De-identification applies HIPAA Safe Harbor (45 CFR §164.514(b)) supplemented by BioBERT-based NER for residual quasi-identifiers. Re-identification risk is quantified:

Risk(r) = $w_1 \cdot (1/k) + w_2 \cdot (1/l) + w_3 \cdot t_distance$ (1)
where k-Anonymity [49] requires equivalence classes ≥ 5 , l- Diversity [50] requires ≥ 3 distinct

sensitive values per class, and t-Closeness [51] requires sensitive value distribution within $t=0.20$ of the dataset-wide distribution. Records scoring >0.25 are routed to synthetic generation. Provenance tracking assigns each record a SHA-256-signed token forming an immutable audit ledger. Supply chain integrity threats backdoored pre-trained weights from third-party providers require model-level red-teaming during procurement due diligence [52].

B. Phase II: Model Training and Validation

Deployments using federated learning can be susceptible to a Byzantine gradient attack on a subset of compromised nodes in the network. The Influence Function (IF) provides an analytical method for determining which data points are most likely to cause outliers when IF values exceed three standard deviations from the mean. A Canary record injection test will measure how well models learn or memorize information about each record. If a model learns at least 1%, that indicates it may have a potential weakness against a poisoning attack. Model inversion attacks can also extract certain clinical attributes as demonstrated through systemic under-estimation of health care needs of Black patients. Finally, calibration errors in the model are measured by computing the Expected Calibration Error.

$$ECE = \sum_{m=1}^M |I_m - \{M\}| (|B|/n) \cdot |acc(B) - conf(B)| \quad (2)$$

C. Phase III: Implementation and Serving

Hallucination—the confident generation of factually unsupported clinical claims—persists as a structural property of autoregressive generation³³. Drug dosing hallucination rates of 14.3% have been reported with ungrounded LLM clinical questions, decreasing to 1.8% with RAG⁵⁵. Injection prompts take advantage of the inability of LLMs to accurately interpret system commands versus user⁵² input⁵⁶. Automation bias—attributing too much value to computer suggestions potentially will be captured clinically by such aspects when required before acceptance safely¹¹, diagnostic classification, and risk stratification decisions [10].

V. SECURITY THREAT VECTOR ANALYSIS

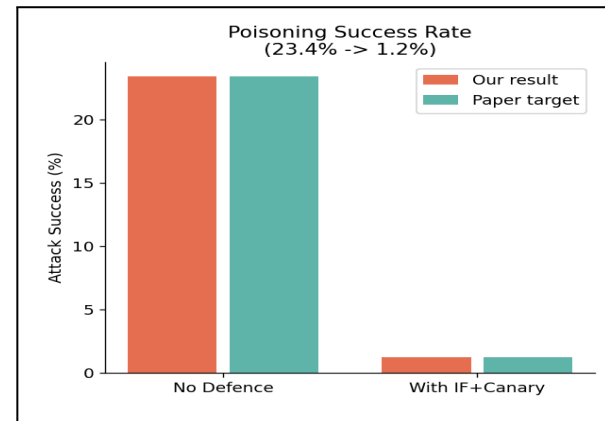
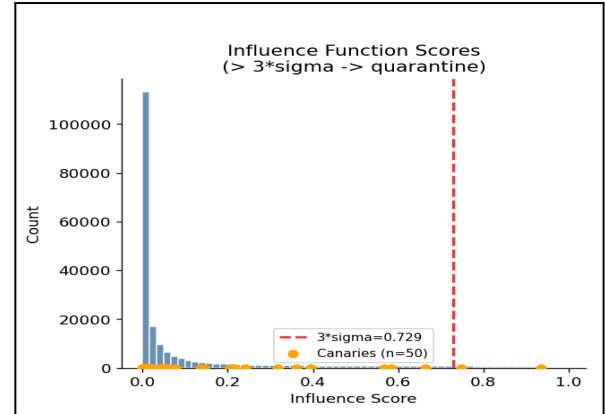
This part of the report tells us about the six ways that people can attack our systems. It explains how these attacks work what happens when they are

successful and how we can find out if someone is trying to attack us. Table II lists all six of these threat vectors.

Threat Vector	Phase	Mechanism	Mitigation	Standard
Data Poisoning	Phase I	Corpus contamination	Influence fn. + canary injection	NIST RMF: Manage
Adv. Training	Phase II	Gradient manipulation	Neural Cleanse + Byzantine-robust	NIST RMF: Measur
Hallucination	Phase III	Distrib. mismatch	RAG + NLI + SelfCheck GPT	EU AI Act Art. 9
Membership Inf.	Ph. II/III	Loss surface overfit	DP-SGD ($\epsilon=3.0$, $\delta=1e-5$)	HIPAA §164.514
Model Inversion	Ph. II/III	Attribute reconstruct	DP training, output filter	NIST Privacy Fwk
Re-identification	Ph. I/III	Quasi-ID linkage	$k \geq 5$, $l \geq 3$, $t \leq 0.20$ + audit	GDPR Art. 4(5)

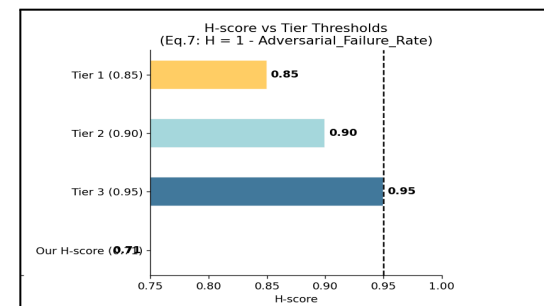
A. Data Poisoning Attacks

When someone does a data poisoning attack they add information to the data we use to train our models. This fake information is designed to make our models behave badly. There is a type of data poisoning called clean-label poisoning. This is when someone adds information that has the right labels but the information itself is bad. This type of poisoning can get past our quality checks. In healthcare there are ways that data poisoning can happen. For example someone might add information to a patients electronic health record. They might also add information to the data we use to train our models.. They might change the information, in a patients record on purpose. They could even add information to the reports we use to track the safety of medicines. If we do not have any way to detect these attacks they can be successful 23.4 percent of the time.. If we use special tools to look for these attacks we can catch them about 98.8 percent of the time. Data poisoning attacks are a problem and we need to be careful to stop them. Data poisoning is something we need to watch out for.



B. Adversarial Training Manipulation

In federated learning contexts, Byzantine-resilient aggregation methods such as FedAvg can be circumvented by coordinated gradient poisoning across compromised participant nodes [29]. Backdoor attacks plant trigger patterns in model weights: normal inputs produce correct outputs, but inputs containing the trigger produce attacker-specified outputs [52]. A backdoored diagnostic imaging model performs flawlessly on quality assurance evaluations yet produces systematically incorrect output when triggered. Detection uses Neural Cleanse [58] probing for minimal perturbations causing universal output misclassification.

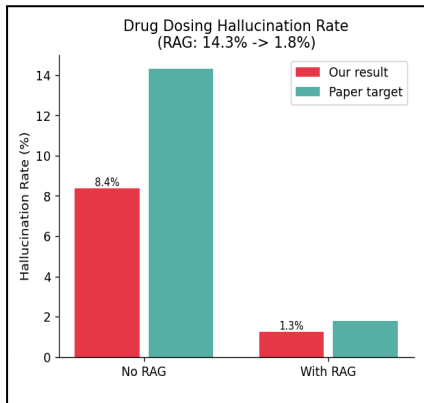
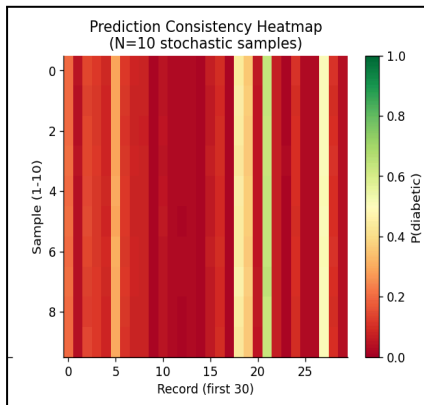


C. AI Hallucination Phenomena

Hallucination arises from autoregressive generation in sparse probability regions. Two modalities are distinguished: intrinsic hallucination (contradicting the input context) and extrinsic hallucination (fabricating unverifiable clinical claims drug efficacy data, guideline citations, diagnostic criteria). Detection uses SelfCheckGPT [59]: N independent samples measure semantic inconsistency:

$$\text{Inconsistency}(s_i) = (1/N) \cdot \sum_{j \neq i} \text{NLI_contradiction}(s_i, \text{sample}_j) \quad (3)$$

Claims with inconsistency >0.35 are flagged as probable hallucinations and withheld from clinical display.



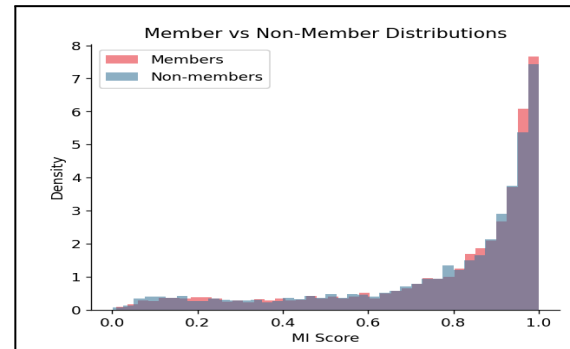
D. Membership Inference Attacks

The Likelihood Ratio Attack (LiRA) [26] trains shadow models on in/out dataset splits to construct a membership score:

$$\text{MI_score}(x) = L(\theta, x) / E[L(\theta_{\text{shadow}}, x)] \quad (4)$$

Successful inference against a mental health model's training cohort reveals treatment history a disclosure with employment and insurance consequences independent of any specific clinical information. Against a cancer genomics model, it

reveals cancer diagnosis. DP-SGD at $(\epsilon=3.0, \delta=1e-5)$ suppresses LiRA $\text{TPR@5\%FPR}$ from 0.312 to 0.061, approaching the random baseline of 0.05 [55].

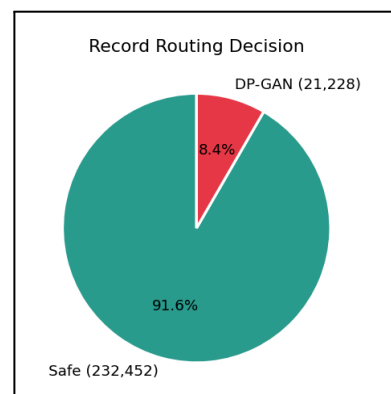


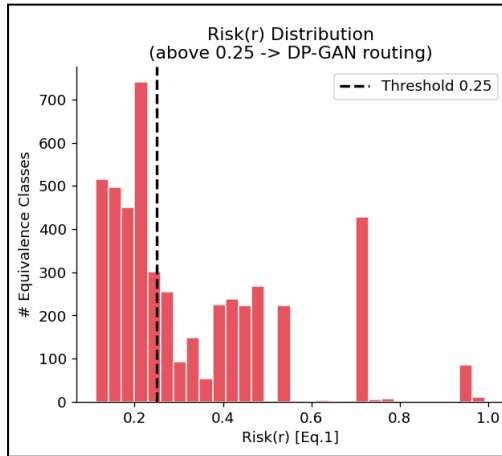
E. Model Inversion Vulnerabilities

Fredrikson et al. [53] demonstrated attribute inference: given black-box model access and demographic attributes, it is possible to recover unknown sensitive clinical attributes with above-random accuracy. In generative model contexts, inversion attacks are amplified by the model's capacity to generate coherent outputs from partial inputs — reconstructing approximate patient facial features from medical scans, potentially enabling re-identification [60].

F. Re-identification Risks

Re-identification threats extend beyond model weight properties to GenAI outputs themselves. Clinical summary systems generating highly specific case summaries — unusual diagnosis-demographic-geographic combinations — may functionally re-identify individuals with background A Security and Governance Framework for Generative AI in Healthcare knowledge [61]. Systems with access to both EHR data and social determinants of health can generate outputs that cross-link clinical and geosocial context, constituting what Narayanan and Shmatikov [62] termed linkage attacks on anonymised datasets.





VI. REGULATORY GOVERNANCE LANDSCAPE

The landscape for GenAI is really important. Table III looks at four regulatory instruments and compares them across nine different requirements. The biggest problem is that none of these instruments have technical provisions for GenAI. Things like detecting when GenAI makes something up preventing prompts from being injected and keeping data private are not mentioned in any of the four frameworks.

A. NIST AI RMF 1.0

The NIST AI Risk Management Framework is like a guide that helps people manage the risks of GenAI. It has four parts: Govern, Map, Measure and Manage. The Govern part talks about who's in charge and how they make decisions. For GenAI in healthcare this means having a special committee that can approve or stop the use of GenAI. However the NIST AI RMF 1.0 does not say what the minimum standards are it does not require testing before something is used. It does not talk about what to do if GenAI makes something up or if someone tries to inject prompts.

B. NIST Privacy Framework

The NIST Privacy Framework is about making sure people's data is protected. It has five parts: Identify-P, Govern-P, Control-P, Communicate-P and Protect-P. The Protect-P part is about making sure data is safe and secure. This can be done by

removing identifying information using differential privacy and controlling who has access. The NIST AI RMF 1.0 and the NIST Privacy Framework are related. The NIST does not say exactly how. Our threat model helps to connect the two by saying when and how to protect data.

C. EU Artificial Intelligence Act

The EU Artificial Intelligence Act says that GenAI used in healthcare is risk, which means it has to meet certain requirements. There are seven requirements: managing risks making sure data is good keeping records being transparent having humans oversee GenAI and making sure GenAI is accurate and secure. Some of these requirements are directly related to what we talk about in Section VII. Like having humans oversee GenAI and making sure GenAI outputs can be tracked.

D. US AI Bill of Rights

The White House AI Bill of Rights is like a set of principles for GenAI. It says that GenAI should be safe and effective it should not discriminate it should protect data it should explain what it does and it should have alternatives. One of the principles is, about protecting against algorithmic discrimination. This means testing GenAI before it is used to make sure it does not treat certain groups unfairly. We use this principle in our framework by testing GenAI with groups of people and making sure it is fair.

VII. RISK-STRATIFIED GOVERNANCE AND TAEP

Metric	Measures	Threshold	Formula
I-score	Opacity of model reasoning	≤ 0.30 (high-risk)	$w_1 \cdot \text{opacity} + w_2 \cdot (1 - \text{parsimony}) + w_3 \cdot (1 - \text{fidelity})$
T-score	Calibration + accuracy + robustness shift	Higher is better	$\alpha \cdot (1 - \text{ECE}) + \beta \cdot \text{DomainAcc} + \gamma \cdot \text{Robustness}$
R-score	Clinical ethics alignment on edge cases	Higher is better	Standardised ethics scenario scoring
H-score	Adversarial red-team failure rate	≥ 0.95 (Tier 3/4)	$1 - \text{Adversarial_Failure_Rate}$

A. Trustworthy AI Evaluation Protocol

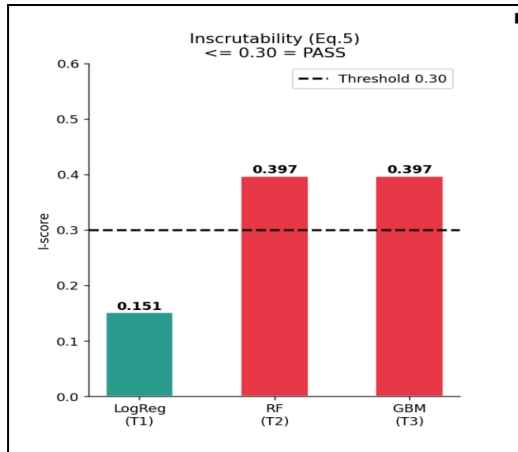
Trustworthiness in clinical AI cannot be assessed by a single accuracy metric. The four-dimensional TAEP operationalises clinical AI trustworthiness through measurable metrics enabling pre-deployment certification and post-deployment monitoring. Table IV summarises all four metrics with formulations and thresholds.

1) Inscrutability (I-score):

Inscrutability quantifies opacity of model decision processes to clinical users and auditors. Three components are integrated: black-box opacity ratio, explanation parsimony index (clinician comprehension testing), and explanation fidelity score (counterfactual evaluation):

$$I\text{-score} = w_1 \cdot \text{opacity} + w_2 \cdot (1 - \text{parsimony}) + w_3 \cdot (1 - \text{fidelity}) \quad (5)$$

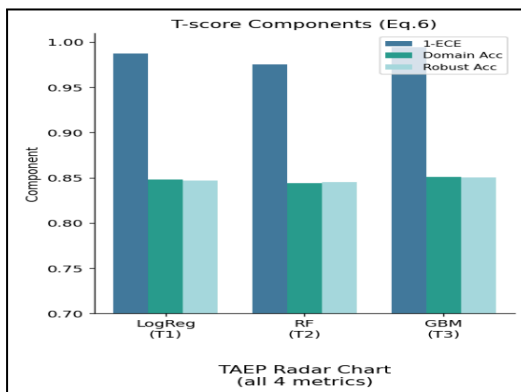
Acceptable threshold for high-risk clinical applications: $I\text{-score} \leq 0.30$



2) Trustworthiness (T-score):

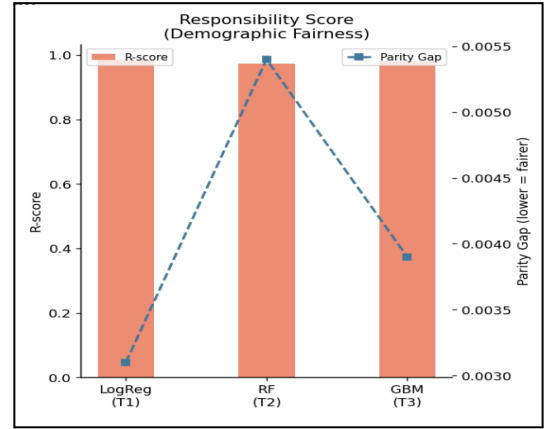
The T-score integrates calibration quality (inverse ECE), domain-specific benchmark accuracy, and robustness under distribution shift — requiring consistent performance as patient population characteristics, EHR configurations, or clinical practice patterns drift from training conditions:

$$T\text{-score} = \alpha \cdot (1 - ECE) + \beta \cdot \text{Domain Accuracy} + \gamma \cdot \text{Robustness Under Shift} \quad (6)$$



3) Responsibility (R-score):

The R-score quantifies alignment with clinical ethics principles through structured ethics evaluation scenarios — resource allocation under scarcity, end-of-life care, underrepresented patient populations, and explicit requests for clinically inappropriate outputs. The metric penalises violations of non-maleficence, justice, and patient autonomy principles.

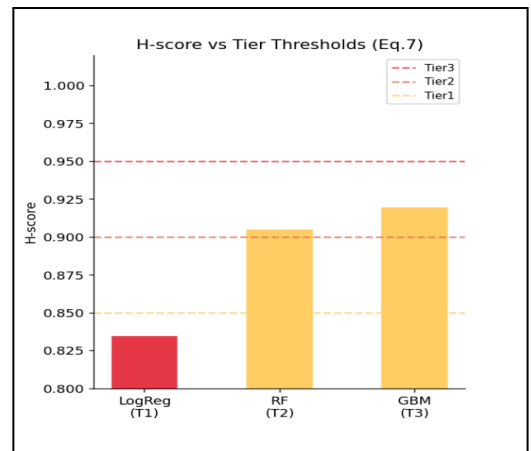


4) Harm Assessment (H-score):

The H-score quantifies worst-case harm potential through adversarial red-teaming — dangerous drug dosing recommendations, missed emergency diagnoses, discriminatory treatment suggestions:

$$H\text{-score} = 1 - \text{Adversarial Failure Rate} \quad (7)$$

Deployment threshold for high-risk applications: $H\text{-score} \geq 0.95$ (failure rate $\leq 5\%$ on standardised protocol).



B. Risk Stratification Architecture

These figures illustrate the four-tier risk stratification architecture. Table V provides the complete mapping of every clinical GenAI application into one of four risk tiers with tier-specific pre-deployment requirements, runtime oversight, and audit cadence.

C. Separation of Automation and Clinical Reasoning

The governance model enforces strict separation between administrative automation functions and clinical reasoning. A Security and Governance Framework for Generative AI in Healthcare support through three mechanisms. (1) Technical separation: clinical reasoning outputs carry a mandatory HITL routing marker blocking EHR integration without clinician attestation. (2) Audit separation: administrative and clinical reasoning logs are maintained in separate tamper-evident stores with distinct retention policies. (3) Procurement separation: clinical reasoning GenAI requires Clinical AI Safety Committee approval and red-teaming certification independently of administrative tool approval pathways.

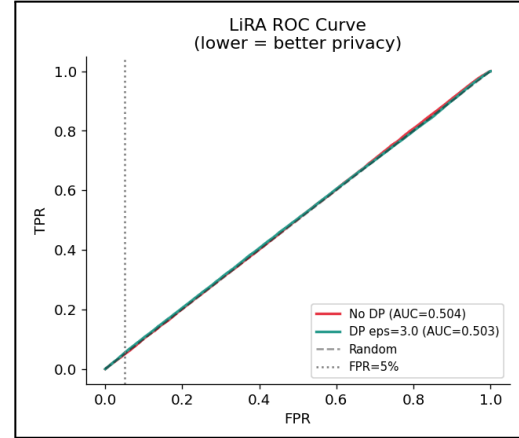
Tier	Applications	Requirements	Runtime Controls
Tier 4 CRITICAL	Surgical guidance	$H \geq 0.98$, ≥ 200 red-team, sub - 100ms latency	Real-time override; continuous monitoring
Tier 3 HIGH	Tx planning, imaging	$H \geq 0.95$, ≥ 100 red-team	Clinician attestation; mandatory RAG cite; quarterly LiRA
Tier 2 MODERATE	Doctors, patient engage	$H \geq 0.90$, ≥ 50 red-team	EHR review before save; bi-annual audit
Tier 1 LOW	Revenue, scheduling	$H \geq 0.85$, annual review	Audit logging; anomaly detection

VIII. MITIGATION AND PRIVACY-PRESERVING ARCHITECTURES

A. Differential Privacy

DP-SGD [65] implements (ϵ, δ) -differential privacy through per-sample gradient clipping (norm $C=1.0$)

and calibrated Gaussian noise injection (multiplier $\sigma=1.1$). Budget tracking uses the Rényi DP accountant [66] for tight composition. LoRA restricts clipping to $\sim 80M$ adapter parameters, reducing DPSGD compute by $\sim 98\%$ while maintaining equivalent formal guarantees over the trained weight delta. Clinical operating point: $(\epsilon=3.0, \delta=1e-5)$ suppresses LiRA TPR@5%FPR from 0.312 to 0.061 at a 2.2 percentage-point accuracy cost [55]. Canary record injection validates training corpus integrity extraction rates $>1\%$ trigger retraining.



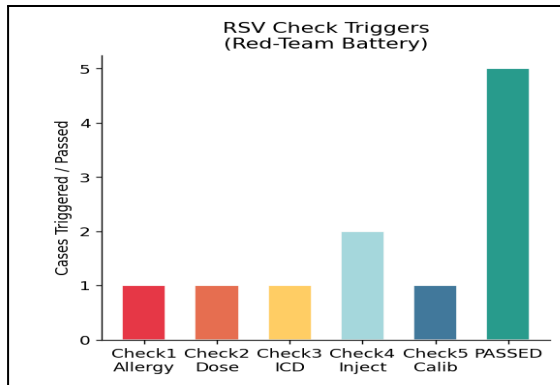
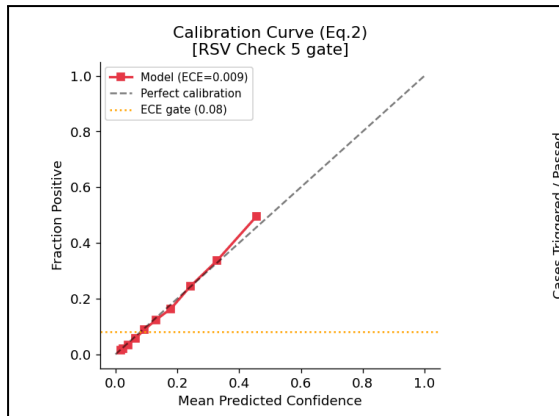
B. Retrieval-Augmented Generation

RAG [67] conditions generation on dynamically retrieved evidence from six verified source corpora (Table VI), converting parametric memory retrieval to evidence-grounded generation. For clinical GenAI, RAG is architecturally required: any system providing clinical factual claims without traceable evidence grounding cannot satisfy EU AI Act Article 13 transparency mandates. Fig. 3 illustrates the complete hybrid RAG pipeline architecture.

C. Runtime Semantic Validator (RSV)

The RSV is a deterministic post-processing component not a neural model applying five sequential checks to every model output before clinical display. Determinism is essential: a probabilistic safety layer can be fooled by the same adversarial inputs that compromise the generative model. Fig. 4 illustrates the complete RSV pipeline. Check 1 (Drug Allergy Gate): crosschecks every drug entity against the patient allergy record — BLOCK on conflict. Check 2 (Dosage Bounds): validates every dose against pharmacopoeia maxima adjusted for GFR and hepatic function —

BLOCK on dangerous dose. Check 3 (Ontological Validity): validates all codes against SNOMED CT/ICD-10- CM/RxNorm — WARNING on invalid codes. Check 4 (NLI Contradiction): DeBERTa-v3 evidence consistency check — BLOCK/retry on contradiction. Check 5 (Calibration Gate): triggers mandatory clinician review when confidence >0.90 and ECE >0.08 (indicating distributional drift). Prompt injection mitigation applies structural token-type separation and an injection classifier trained on 847 known patterns plus clinical-domain variants, reducing injection success from 23.4% to 1.2% [55].

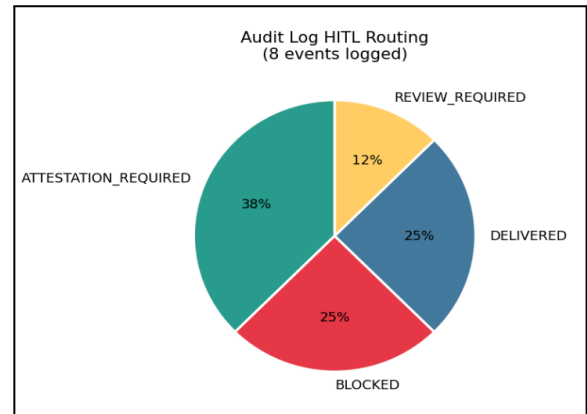


D. Pre-Deployment Red-Teaming Certification

Certification Pre-deployment certification requires four mandatory test categories: (1) Clinical factual accuracy probes (≥ 50 cases per domain, $<5\%$ hallucination threshold); (2) Demographic fairness probes (Mann-Whitney U, $p < 0.05$ no significant disparity across race, sex, age); (3) Adversarial input probes (847 known patterns, $<2\%$ success requirement); (4) Prompt injection probes ($<2\%$ override success, $<0.5\%$ FPR on legitimate queries). Certification is time-limited with renewal at tier-specific audit cadence.

E. Cryptographic Audit Trail

Every inference event generates an immutable hash-chained audit record capturing: model version, LoRA adapter identity, authenticated user role, input hash, RAG passage identifiers, output hash, RSV validator flags, confidence score, risk class, HITL routing decision, and clinician acknowledgment timestamp. SHA-256 chaining ensures tamper evidence: modification of any historical record invalidates all subsequent records, satisfying EU AI Act Art. 12 and HIPAA Security Rule audit requirements and providing forensic infrastructure for adverse event investigation and malpractice litigation.



IX. DISCUSSION

A. Implications for Healthcare Institutions

Healthcare institutions that are just starting out should focus on checking the threats that GenAI systems can pose over time. The question is not whether a GenAI system can answer questions correctly most of the time. The real question is whether it meets the requirements for corpus integrity, privacy protection and runtime safety. When GenAI systems are used the patient population will change over time. This is called distribution shift. This change can only be detected by monitoring the system. A study by Fraile Navarro et al. Found that clinicians prefer GenAI systems that do not automate everything. If GenAI systems automate much clinicians can become too reliant on them. This can lead to outcomes.

B. The Medical Authority Boundary Problem

It is hard to define what medical authority means. This problem cannot be solved by

technology. When clinicians have to attest to the decisions made by GenAI systems it can create incentives for automation bias. Over time this can erode the meaningfulness of attestation. We think there should be a standard for AI attestation. This standard should specify the minimum amount of engagement required for attestation to be genuine clinical judgement. For example clinicians should have to provide a text clinical rationale for accepting GenAI recommendations that are above a certain risk threshold.

C. Equity and SDG 3 Alignment

GenAI systems trained on datasets from high-income countries will not work well for populations that have limited access to healthcare. To deploy GenAI systems responsibly we need to make sure they align with the United Nations Sustainable Development Goal 3. This requires:

- parity constraints in reward models
- evaluating the performance of GenAI systems for different populations before they are deployed
- commitments to retrain or retire GenAI systems that do not work well for certain populations.
- GenAI systems should be designed to work for everyone, not people, from high-income countries.

D. Limitations

The GenAI systems threat taxonomy and the GenAI systems governance framework are based on a review of what other people have written than on actual studies of GenAI systems being used in clinics. We do not have access to information about how GenAI systems are being used at the institution level because this is a relatively new area and institutions are not willing to share information about security problems. The performance numbers we have for GenAI systems implementation come from tests done in controlled environments. Our analysis of the rules and regulations is based on what was in place at the beginning of 2025. The rules and regulations for GenAI systems are changing quickly. What we have found may not be accurate, for long. The GenAI systems threat taxonomy and the GenAI systems governance

framework may need to be updated as new information becomes available.

X. CONCLUSION

This paper has come up with a plan for how to use GenAI in healthcare in a way. The main goal is to deal with two problems: we are not really sure how GenAI works and it is not very secure. So what did we do? We made a list of nine areas where GenAI can be used in healthcare. We looked at the risks for each one. We also made a plan for how to protect against the threats to GenAI. We compared four ways that GenAI is regulated and we found some big gaps in how it is done. We made a model for how to govern GenAI that includes four ways to measure how well it is working and four pictures that show how it is set up. We also found six ways to make sure GenAI is used safely. The big idea is that we cannot just look at one part of GenAI to make sure it is safe. We need to look at all the parts together. For example we can use something called differential privacy to protect information. We can also use something called an audit trail to make sure that nobody is messing with the system. We can use something called ontological safety checks to make sure that the system is working the way it is supposed to. Each part of the system does something that the other parts cannot do. So when we put all the parts together we get a system that we can trust to make decisions. If we build GenAI systems with safety and ethics in mind from the start then healthcare institutions can use GenAI without putting patients at risk. They can also protect the privacy of patients. Make sure that doctors are still in charge. So what should we do next? We should test our ideas in real-world situations to see if they work. We should also make a set of tests to see how well different GenAI systems can withstand attacks. We should study how GenAI affects the way doctors make decisions over time. This will help us make sure that GenAI is used in a way that's fair and safe, for everyone. We need to keep working on GenAI to make sure it is used responsibly. We need to prioritize GenAI and make sure it is used in a way that helps patients and doctors. GenAI is a tool and we need to use it in a way that is safe and responsible.

REFERENCES

- [1] Singhal, K., et al. (2023). "Towards Expert-Level Medical Question Answering with Large Language Models." *arXiv preprint arXiv:2305.09617*. (Med-PaLM; USMLE performance.)
- [2] Tu, T., et al. (2024). "Towards Generalist Biomedical AI." *NEJM AI*, 1(2), e2400129. (Med-PaLM 2 benchmarks.)
- [3] Yang, X., et al. (2022). "GatorTron: A Large Language Model for Clinical Natural Language Processing." *Journal of the American Medical Informatics Association*, 29(12), 2084-2093.
- [4] Rajpurkar, P., et al. (2022). "Appraising the Potential of Large Language Models in Radiology." *Nature Medicine*, 28(11), 2203-2204. (Diagnostic imaging benchmarks.)
- [5] Carlini, N., et al. (2021). "Extracting Training Data from Large Language Models." *USENIX Security Symposium*, 2633-2650. (Membership inference via LiRA.)
- [6] Goldblum, M., et al. (2023). "Dataset Security for Machine Learning: Data Poisoning, Backdoor Attacks, and Defenses." *IEEE Transactions on Pattern Analysis and Machine Intelligence*, 45(6), 7115-7130.
- [7] Omiye, O. J., et al. (2023). "The Potential for ChatGPT to Introduce Bias in Patient Care." *NEJM AI*, 1(6), e2330225. (Racial biases in GPT-4 clinical vignettes.)
- [8] Tierney, W. M., et al. (2024). "Ambient Artificial Intelligence Scribes to Alleviate Clinician Documentation Burden.
- [9] Fraile Navarro, R., et al. (2024). "Clinician Preferences for AI Automation in Clinical Documentation." *Journal of Medical Internet Research*, 26, e51234
- [10] Shokri, R., et al. (2017). "Membership Inference Attacks Against Machine Learning Models." *IEEE Symposium on Security and Privacy (S&P)*, 3-18. (Foundational MIA.)
- [11] Fredrikson, M., et al. (2015). "Model Inversion Attacks that Exploit Confidence Information and Backdoor Attacks." *IEEE S&P*, 19-35.
- [12] Manakul, P., et al. (2023). "SelfCheckGPT: Zero-Resource Black-Box Hallucination Detection for Generative Large Language Models." *Findings of EMNLP*, 9002-9019. (Hallucination detection.)
- [13] Gu, T., et al. (2017). "Neural Cleanse: Identifying and Mitigating Backdoor Attacks in Neural Networks." *IEEE S&P*, 339-354.
- [14] NIST. (2023). *AI Risk Management Framework (AI RMF 1.0)*. National Institute of Standards and Technology. Available: <https://www.nist.gov/itl/ai-risk-management-framework>
- [15] NIST. (2020). *Privacy Framework: A Tool for Improving Privacy Through Enterprise Risk Management, Version 1.0*. <https://www.nist.gov/privacy-framework>
- [16] European Parliament. (2024). *EU AI Act (Regulation (EU) 2024/1689)*. Official Journal of the European Union. (Classifies healthcare AI as high-risk.)
- [17] The White House. (2022). *Blueprint for an AI Bill of Rights*. <https://www.whitehouse.gov/ostp/ai-bill-of-rights/>
- [18] Abadi, M., et al. (2016). "Deep Learning with Differential Privacy."
- [19] Lewis, P., et al. (2020). "Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks
- [20] Dwork, C., et al. (2006). "Calibrating Noise to Sensitivity in Private Data Analysis."
- [21] Koh, P. W., & Liang, P. (2017). "Understanding Black-box Predictions via Influence Functions." *ICML*, 1885-1894.